Sovereign Data Gateway: A Privacy-Preserving Policy Enforcement Gateway (Project Proposal)

Project Code
SADG-2026-01

Project Supervisor
Sir Saad Razzaq (internal)

Project Manager
Dr.Muhammad Ilyas

Project Team
Muhammad Rizwan Hanzala , Reg. No. S046 — Team Lead
Ameer Hamza , Reg. No. S001 — Team Member

Submission Date
13 OCT 2026

Table of Contents

1. Abstract 2

2. Background and Justification 2

3. Research Methodology 3

4. Project Scope 3

5. High Level Project Plan 4

6. References 4

1. Abstract

AI chat tools such as ChatGPT, Claude, and Grok are now used for everyday and professional tasks that frequently involve sensitive personal and financial information. Independent studies show that a meaningful share of users regularly paste sensitive data into these tools [1], [2], and regional financial regulators have begun responding directly: Bangladesh Bank has formally prohibited staff from entering confidential data into AI tools [3], while the State Bank of Pakistan is finalizing AI governance guidelines for a sector where nearly half of surveyed institutions already use AI [4].

This project proposes the Sovereign Data Gateway, a gateway that sits between a user and an AI service, detects sensitive data in the outgoing text, applies a configurable policy to decide what may leave, replaces sensitive values with tokens before transmission, and restores the real values in the response only where policy permits. The system will be built as a browser extension and an API proxy, with detection extended specifically to English and Roman Urdu and Pakistani identifier formats, a gap not addressed by existing commercial or open-source tools.

The expected benefit is a measured, regionally relevant contribution to AI data-leakage prevention, together with practical experience in cloud architecture and applied security engineering.

2. Background and Justification

The underlying problem is well documented. A study of employee behaviour found that a significant proportion of staff regularly submit company data to AI chat tools, often without organizational visibility [1], [2]. In Pakistan specifically, this risk intersects with an active regulatory direction: the National Data Governance Policy treats government and sovereign data as subject to Pakistani jurisdiction, and specific government procurement requirements mandate that certain project data, logs, backups, and cryptographic keys remain hosted within Pakistan. The banking sector illustrates the urgency directly — Bangladesh Bank has already banned staff from entering confidential data into AI tools including ChatGPT, Gemini, Claude, Grok, and DeepSeek [3], and the State Bank of Pakistan is simultaneously developing its own AI governance guidance [4].

Several bodies of existing work address related aspects of this problem. Academic research has proposed local pre-processing of prompts before they reach a cloud AI service: Casper replaces personal data with placeholders prior to submission to web-based AI services [6]; PromptGraph protects only the privacy-sensitive portions of a prompt and verifies placeholders before restoration [7]; and a broader survey catalogues threats and mitigation approaches for large language model privacy [8], [5]. On the tooling side, Microsoft Presidio provides an open-source framework for detecting and anonymizing personal data with custom recognizers [9], and LiteLLM applies Presidio-based masking across calls to multiple AI providers, though its own documentation and issue tracker report unresolved failures when restoring values in streamed responses [10].

Cloud providers offer native options as well: Amazon Bedrock Guardrails can mask or block personal data in prompts and responses [12], and Azure AI Language lists Urdu among its supported languages for PII detection [13], though both are detection APIs rather than complete, locally controlled gateways. Commercially, products such as Nightfall, Microsoft Purview, and Netskope already protect organizations using AI tools; however, Netskope's own user community has documented that its

detection supports English primarily, with non-English identifiers such as names and addresses likely to bypass detection entirely [11].

None of the above work combines detection tuned to Urdu and Roman Urdu with Pakistani identifier formats, a policy layer that decides what data may leave before detection occurs, and a local vault architecture in which the cloud AI provider never receives the real sensitive values. Academic work on Urdu named-entity recognition exists [14] and Roman Urdu is independently documented as a low-resource language with limited tooling [15], but neither has been applied to this specific gateway problem. This project is justified as an extension of the existing body of work into this underserved combination, evaluated with a measurable methodology rather than asserted as an improvement.

3. Research Methodology

The system will be developed and evaluated through the following steps:

- Architecture: two entry points — a browser extension for a chat website and an API proxy for applications using AI APIs — both forwarding text to a single gateway engine.
- Detection: rule-based pattern matching for structured identifiers (CNIC, Pakistani phone numbers, email), and a named-entity-recognition model for names and addresses in English and Roman Urdu, implemented as custom recognizers within the Microsoft Presidio framework [9].
- Policy evaluation: detected items are classified into public, internal, personal, and critical tiers, and a policy engine decides which items may be transmitted and which must be withheld.
- Tokenization and vault: items permitted to leave are replaced with tokens; the real values and their mapping are stored in an encrypted local vault with the encryption key managed through AWS Key Management Service, and are never transmitted to the AI provider.
- AI processing: the tokenized text is sent to the selected AI provider (Amazon Bedrock and one additional provider).
- Restoration: the AI response is scanned for tokens, which are replaced with real values only where policy permits; handling of tokens split across streamed response chunks will be implemented and tested explicitly.
- Evaluation: five experiments will be conducted — (i) detection accuracy (precision, recall, F1) across English and Roman Urdu test data; (ii) leakage rate reaching the AI provider, compared against a Presidio-only baseline; (iii) AI response utility with and without the gateway; (iv) latency, measured separately for detection, tokenization, the AI call itself, and restoration; and (v) resistance to adversarial bypass attempts, including spacing variation, mixed scripts, and structured data formats.

4. Project Scope

In scope:

- Text and JSON input; detection of CNIC numbers, phone numbers, email addresses, names, and addresses in English and Roman Urdu.
- A policy engine with four data-sensitivity tiers and a locally controlled, encrypted vault.

- A browser extension for one chat website and an API proxy supporting at least two AI providers.
- An audit log and a dashboard for policy configuration and reviewing detected/transmitted data.
- The five-experiment evaluation methodology described in Section 3.

Out of scope:

- Protection for non-AI applications such as banking systems or games — identified as future work.
- Full Nastaliq Urdu script support — treated as a stretch goal, not a core evaluation requirement.
- Multi-cloud deployment, Kubernetes, training a custom large language model, and blockchain-based components.
- Support for every chat website or AI provider; the prototype targets a limited, representative set.

5. High Level Project Plan

Activity	Time Allocated	Resources
Repository setup, message-format agreement between gateway and client, test-data planning	Week 1	Both team members
Detection engine: rule-based recognizers and NER model for English and Roman Urdu	Weeks 2–3	Team Lead
Policy engine, tokenization, and encrypted local vault (AWS KMS)	Week 4	Team Lead
AI provider integration and response restoration logic, including streaming	Week 5	Team Lead
Browser extension, policy dashboard, and audit log interface	Weeks 1–5 (parallel)	Team Member
Evaluation: the five experiments defined in Section 3	Weeks 6–7	Both team members
Documentation, threat model, cost report, and demonstration rehearsal	Week 8	Both team members

Table 5.1: Project Schedule, Task Distribution, and Milestones (Weeks 1–8)

6. References

[1] Cybernews, "Workers regularly post sensitive data into ChatGPT," 2025. [Online]. Available: https://cybernews.com/security/workers-regularly-post-sensitive-data-into-chatgpt/

[2] Axios, "Workers are spilling secrets to chatbots," Jul. 31, 2025. [Online]. Available: https://www.axios.com/2025/07/31/workers-company-secrets-chatgpt

[3] The Business Standard, "Don't use confidential data in AI tools: Bangladesh Bank," 2026. [Online]. Available: https://www.tbsnews.net/node/1478471

[4] Profit by Pakistan Today, "SBP to finalize guidelines for responsible AI use in Pakistan's financial sector," Apr. 27, 2025. [Online]. Available: https://profit.pakistantoday.com.pk/2025/04/27/sbp-to-finalize-guidelines-for-responsible-ai-use-in-pakistans-financial-sector

[5] "Guarding Your Conversations: Privacy Gatekeepers for Secure Interactions with Cloud-Based AI Models," arXiv:2508.16765, 2025.

[6] "Casper: Prompt Sanitization for Protecting User Privacy in Web-Based Large Language Models," arXiv:2408.07004, 2024.

[7] "PromptGraph: Graph-Guided Prompt Sanitization for Balancing Privacy and Utility in LLM Inference," arXiv:2607.10709, 2026.

[8] "Preserving Privacy in Large Language Models: A Survey on Current Threats and Solutions," arXiv:2408.05212, 2024.

[9] Microsoft, "Presidio: Data Protection and De-identification SDK," GitHub repository. [Online]. Available: https://github.com/microsoft/presidio

[10] BerriAI, "PII Masking (Presidio) — LiteLLM Guardrails," LiteLLM Documentation. [Online]. Available: https://docs.litellm.ai/docs/proxy/guardrails/pii_masking_v2

[11] Netskope Community, "Understanding Netskope DLP's approach to language support and keyword detection," 2024. [Online]. Available: https://community.netskope.com/dlp-7/understanding-netskope-dlp-s-approach-to-language-support-and-keyword-detection-7720

[12] Amazon Web Services, "Guardrails for Amazon Bedrock." [Online]. Available: https://aws.amazon.com/bedrock/guardrails/

[13] Microsoft, "Personally Identifiable Information (PII) Detection Language Support," Azure AI Language Documentation. [Online]. Available: https://learn.microsoft.com/azure/ai-services/language-service/personally-identifiable-information/language-support

[14] "EDU-NER-2025: Named Entity Recognition in Urdu Educational Texts using XLM-RoBERTa," arXiv:2504.18142, 2025.

[15] "Roman Urdu as a Low-Resource Language: Building the First IR Dataset and Baseline," in Proc. Workshop on Low-Resource NLP, 2025.